



Five Ways Cyber Attackers Exploit **Cloud Environments**



ReliaQuest
Threat Research

A detailed analysis of five common cloud-based attack types that can bypass traditional security measures—including exploiting unsecured Secure Shell (SSH) keys, hosting phishing links in cloud storage, and more—and actionable strategies to mitigate them.

Executive Summary



Cloud-Based API Compromise

Cloud APIs enable seamless communication in cloud ecosystems but also introduce significant security risks. For instance, compromised API keys can lead to unauthorized access and manipulation of cloud resources. Common issues include weak authentication, lack of encryption, and poor key management. Understanding and mitigating these risks is crucial for promptly addressing suspicious behavior and protecting cloud environments, especially as more organizations adopt cloud-based services.



SaaS-Based Phishing Attacks

In 2023, phishing accounted for the majority of tactics, techniques, and procedures (TTPs) we observed in cloud software-as-a-service (SaaS) platforms. Threat actors now exploit these trusted platforms by embedding malicious links in documents, such as OneNote files shared via SharePoint. This method bypasses traditional email security and takes advantage of users' trust in these platforms. Consequently, defenders face challenges with effective threat detection and response as security tools struggle to detect threats within trusted domains. This underscores the importance of not overlooking this simple yet increasingly effective attack method.



SSRF Through PaaS

As organizations expand their cloud environments, platform-as-a-service (PaaS) solutions like Grafana are essential for managing cloud resources. However, they also introduce security risks, particularly server-side request forgery (SSRF). Attackers exploit SSRF vulnerabilities by manipulating URLs within the server code to access internal resources, potentially leading to unauthorized data access or remote code execution. In November 2023, ReliaQuest remediated a customer incident where an attacker conducted an SSRF attack on the customer's Grafana platform, gaining access to Amazon Web Services (AWS) resources.



Exploiting Unsecured SSH Keys

Secure Shell (SSH) is vital for modern network management but poses significant security risks when keys are inadequately protected. Attackers can exploit unsecured or misconfigured SSH keys to breach cloud environments, leading to extensive network access and potential financial and operational damage. Defenders face challenges managing SSH keys due to key sprawl and lack of visibility, which increase the risk of security breaches. To mitigate these threats, effective SSH key management practices, including centralized visibility and regular key rotation, are essential.



Cloud Environment Hijacking

Compromised API keys in cloud environments like AWS can lead to significant risks, including unauthorized access, cryptocurrency mining, data theft, and phishing campaigns. Attackers target virtual machines and data buckets, resulting in financial and reputational damage to organizations. Additionally, email services like Simple Email Service (SES) can be hijacked for phishing attacks to evade detection. As threats become increasingly sophisticated and target cloud environments, a proactive defense strategy is crucial. This approach allows organizations to secure their cloud environments before it's too late.

Table of Contents

Introduction 1

Understanding Cloud-Based API Compromise Attacks..... 2

 Case Study.....3

 Mitigations and Recommendations.....4

SaaS-Based Phishing Attacks: Methods and Impact 5

 Case Study.....6

 Mitigations and Recommendations.....7

SSRF Threats in PaaS Environments 8

 Case Study.....9

 Mitigations and Recommendations.....10

Exposing the Risk of Unsecured SSH Keys..... 10

 Case Study.....11

 Mitigations and Recommendations.....12

Protecting Against Cloud Environment Hijacking..... 12

 Case Study.....13

 Mitigations and Recommendations.....14

Cyber Threat Projections 15

 Cloud Exploit Development on the Rise.....15

 Surge in APTs Employing Cloud Services for C2 Operations15

 Hybrid Cloud Misconfigurations.....15

Conclusion..... 16

Appendix: Endnotes..... 17

Introduction

As companies migrate resources from on-premises infrastructure to the cloud, they face a new wave of evolving threats from cyber adversaries who are quickly adapting to the new attack surface.

Cloud environments often offer increased security due to timely patching and significant investments by cloud service providers (CSPs). However, the shared responsibility model means that while CSPs manage the security of their cloud infrastructure, customers are responsible for securing their data and applications. This introduces unique attack vectors that can be challenging to detect and manage, requiring customers to establish vigilant oversight and robust security practices.

As cloud adoption accelerates, understanding the evolving threat landscape becomes increasingly critical. Cloud-based attacks are diverse and constantly evolving, with threat actors directly targeting cloud environments or using cloud services for malicious activities like phishing. To effectively detect, prevent, and respond to these threats, organizations should adopt a robust and holistic approach that unifies the three primary pillars of cloud security: raw logs, native tools, and third-party tools.

In this report, we examine the critical attack vectors associated with three primary types of cloud environment:

Infrastructure-as-a-Service (IaaS)

Offers on-demand infrastructure like computational, storage, and networking resources. Providers like AWS or Azure manage the hardware, while customers handle the software and security.



Software-as-a-Service (SaaS)

Delivers ready-to-use applications (e.g., Google Workspace or Microsoft 365). Providers manage and secure the apps, but customers must follow best practices for access and data protection.



Platform-as-a-Service (PaaS)

Supplies tools and resources for developing and managing applications (e.g., Google App Engine or Azure App Services). Providers and customers share security responsibilities, focusing on application code and data.



IaaS presents a larger attack surface compared to other cloud environments, as customers are responsible for securing their virtual machines, storage, and networking components. Attack vectors in IaaS environments typically target misconfigurations or vulnerabilities within these elements. Conversely, while SaaS environments are largely managed by the provider, they still face challenges, particularly with vulnerabilities in application code and configuration settings. Without the right protections, exploitation of these vulnerabilities can lead to unauthorized access, data breaches, and drastic disruptions to business operations.

In this report, we focus on five major threats that target cloud environments: **compromising cloud APIs, exploiting unsecured Secure Shell (SSH) keys, hosting phishing links in cloud storage, executing server-side request forgery (SSRF) attacks, and phishing via exploited API keys.**

For each threat, we provide:

- In-depth analysis
- Takeaways for defenders
- Case study
- Effective mitigations

These insights are designed to help you better understand the most pressing threats to cloud environments and enhance your security posture by offering actionable steps to mitigate these threats within your own environment.



According to the International Data Corporation (IDC) Worldwide Software and Public Cloud Services Spending Guide, global spending on public cloud services is projected to reach **\$805 billion in 2024** and double by 2028¹.

Understanding Cloud-Based API Compromise Attacks

Cloud APIs are essential for modern cloud ecosystems, enabling seamless communication between applications and systems. However, they also pose significant security risks. API keys are unique identifiers used to authenticate and authorize API requests. If these keys are compromised, attackers can gain unauthorized access to cloud resources and manipulate them as if they were legitimate users.

Common flaws in cloud APIs include:



Weak Authentication



Lack of Encryption



Insecure Endpoints



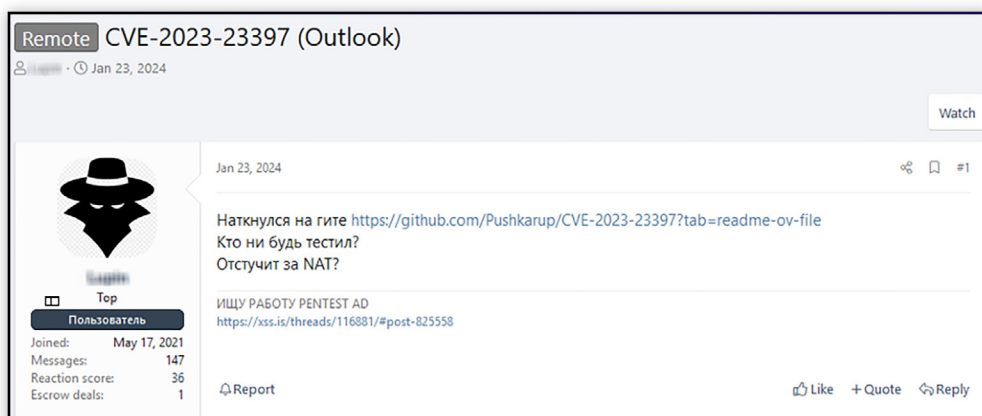
Poor Key Management



Flawed API Logic

These vulnerabilities provide multiple attack vectors for cybercriminals. For example, weak authentication allows attackers to bypass security controls, and inadequate encryption exposes sensitive data to interception. Insecure endpoints might be exploited to access internal systems, and poor key management, such as not rotating keys or using weak keys, can result in compromised API keys. Cybercriminals exploit these flaws to steal access keys, maintain persistence within cloud environments, and perform malicious activities, such as accessing sensitive data, manipulating resources, and evading detection.

ReliaQuest has observed widespread interest in exploiting cloud vulnerabilities to achieve initial access on dark web forums, where threat actors frequently share exploits and discuss methods to compromise these environments.



For instance, in January 2024, a user on the Russian-language cybercriminal forum XSS initiated a thread about CVE-2023-23397—a critical vulnerability in Microsoft Exchange Server.

This vulnerability allows unauthenticated attackers to send specially crafted emails to a vulnerable Exchange Server to potentially execute code and gain unauthorized access.

Figure 1: XSS user posts about testing CVE-2023-23397

Once attackers have gained access, they can exploit cloud APIs to further escalate privileges and move laterally within an environment. This demonstrates how cloud API abuse can also serve as a secondary attack vector after initial access is achieved by other means. The ramifications of this vulnerability affect both on-premises deployments and cloud environments, particularly in hybrid setups involving Exchange Online as part of Microsoft 365.

A GitHub link to a proof of concept (PoC) for exploiting the CVE-2023-23397 vulnerability was included in the forum post and the author of the post asked, “has anyone tested it?” The post quickly garnered engagement from other users, indicating interest among threat actors in exploiting CVE-2023-23397. On the same day, another user asked if anyone had tested the PoC. A third user offered to write about the testing they planned to carry out, but no follow-up posts were made indicating that they had done so.

Case Study

OVERVIEW:

In this case study, we examine API access attempts across a dataset of true positive alerts collected from ReliaQuest customers between December 2023 and September 2024.

The data focuses on initial access and discovery commands run against public-facing cloud APIs, providing insights into how defenders can stop or prevent attacks. We observed that the `GetVersion` command for Kubernetes and self-service password reset requests against public login portals were the most prevalent in the dataset.

The `GetVersion` command appeared in 31% of alerts in Kubernetes—a platform widely used for automating software deployment, scaling, and management. This command helps attackers identify software vulnerabilities, which they can exploit to gain access to an environment. The frequency of this command emphasizes the need for organizations to promptly patch publicly exposed cloud software when critical vulnerabilities are discovered.

Additionally, self-service password reset requests accounted for 28% of all alerts and help attackers gain access to a cloud environment and potentially administrator privileges. Other notable commands, such as `DescribeVolumes`, `GetObject`, and `GetCallerIdentity`, offer valuable insight into attackers' objectives when probing public cloud environments.

The IP addresses in this dataset reveal the services used to launch these attacks. For instance, 17% of attacks originated from cloud platforms like AWS. TOR nodes and obscure cloud services like UCloud were used in 8% of alerts, while services like Alibaba and Scaleway appeared in isolated alerts, demonstrating the diverse range of cloud services that attackers use. Overall, 50% of the source IP addresses showed extensive malicious activity through intelligence searches, indicating consistent use for scanning organizations and probing for weak spots.

This case study and our observations on dark web forums highlight the prevalence of API attacks on cloud environments and their potential to cause critical damage to organizations. This underscores the importance of maintaining robust security defenses to minimize the risk of compromise, which we will explore in detail in the next section.

Mitigations and Recommendations

Deny direct remote access to internal cloud resources using network proxies, gateways, and firewalls. Place cloud-based assets not needed for public-facing business purposes behind a firewall or other perimeter defenses. Implement strong network segmentation to protect assets from commands or traffic that could identify and exploit vulnerabilities. For assets that must be public-facing, strictly monitor for abnormal traffic and commands, such as GetVersion, DescribeVolumes, or GetObject, that could indicate malicious activity.

GreyMatter, our security operations platform, provides centralized monitoring and alerting of API activity to ensure rapid detection and response to suspicious behavior. It integrates with core cloud security layers for comprehensive visibility into multiple cloud-based APIs, including native cloud security tools like GuardDuty and cloud access security brokers (CASBs) like Orca.

To protect against cloud API attacks, the following detection rule can be deployed by GreyMatter to identify the attack, and the associated Response Playbook can be executed by ReliaQuest customers or the ReliaQuest team to remediate the attack.

Detection Rule: RQ – API Call from Threat Host

MITRE ATT&CK ID:

- T1133 – External Remote Services
- T1021.007 – Cloud Services

Summary:

API endpoints are often accessible via public IP addresses. Attackers typically attempt to use external API calls after obtaining credentials to probe the environment or achieve their objectives. This rule detects successful API calls made from external malicious IP addresses.

Implementing GreyMatter Response Playbooks in your incident response plan can expedite and automate responses to potential threats. For the fastest remediation, enable GreyMatter Automated Response Playbooks to automatically contain threats, reducing your mean time to contain (MTTC) and minimizing potential damage.

Alternatively, set GreyMatter Response plays to “RQ Approved” for our analyst team to handle remediation on your behalf, speeding up the process. Note that certain Response Playbooks, like “Isolate Host,” can be configured to require phone approval to avoid business disruption.

We recommend the following Response Playbook:



Block IP: This playbook blocks malicious IP addresses from making malicious API calls to a cloud environment, thus preventing attackers from accessing compromised accounts or executing additional commands. This limits an attacker’s ability to carry out their intended activities within the cloud environment.

SaaS-Based Phishing Attacks: Methods and Impact

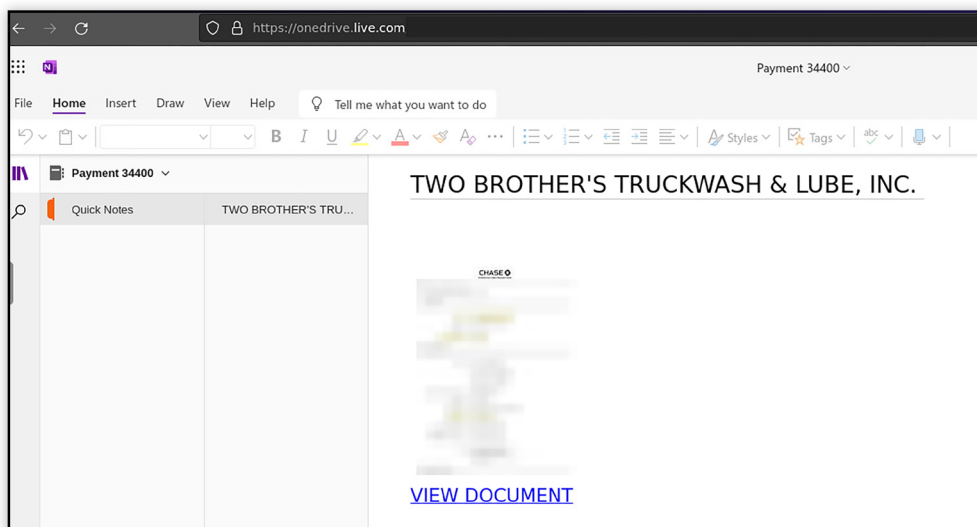
In 2023, [phishing represented a staggering 71.1% of all TTPs](#) observed in ReliaQuest customer true-positive incidents, highlighting its prevalence as a major initial access vector. A phishing tactic that has gained traction in recent years involves hosting phishing links within cloud storage SaaS solutions, such as OneNote files shared via SharePoint or Google documents shared via Google Drive.

In this scenario:

- 1 An attacker creates a phishing document, such as a OneNote file, that contains embedded links to malicious websites. This document is uploaded to a cloud storage platform like SharePoint.
- 2 The attacker sends a phishing email to their targets, including a link to the phishing document hosted on the legitimate cloud platform. Because the email contains a link to a trusted domain, traditional email security tools may not flag the email as suspicious.
- 3 When the recipient clicks the link, they are directed to the document on the cloud platform, which then redirects them to a malicious website or prompts a malware download.

This method exploits the inherent trust users place in well-known cloud storage platforms like Google Drive or Dropbox. By embedding malicious links within documents hosted on these legitimate platforms, attackers can effectively disguise their phishing attempts. In addition, if a phishing page is taken down, malicious links in the files stored on SaaS solutions can be changed and the threat actor can continue their campaign.

This tactic also complicates detection and response efforts. As the initial document link points to a legitimate platform, email filtering systems may not recognize it as malicious, allowing the phishing email to bypass initial security measures. Traditional email security tools struggle to scan links within documents hosted on trusted cloud platforms, making it difficult to identify the threat. Additionally, a phishing document hosted on a cloud platform can remain accessible for extended periods, increasing the likelihood of more users being compromised by the attack.



Once a user clicks on a malicious link, attackers can steal sensitive information, deploy malware, or gain unauthorized access to internal systems. This can lead to further exploitation, such as lateral movement within the network, data exfiltration, and ransomware attacks.

This illustrates the severe implications of a successful phishing attack, leaving organizations impacted by financial losses, data breaches, and significant damage to their reputation.

Figure 2: OneNote phishing document hosted in OneDrive

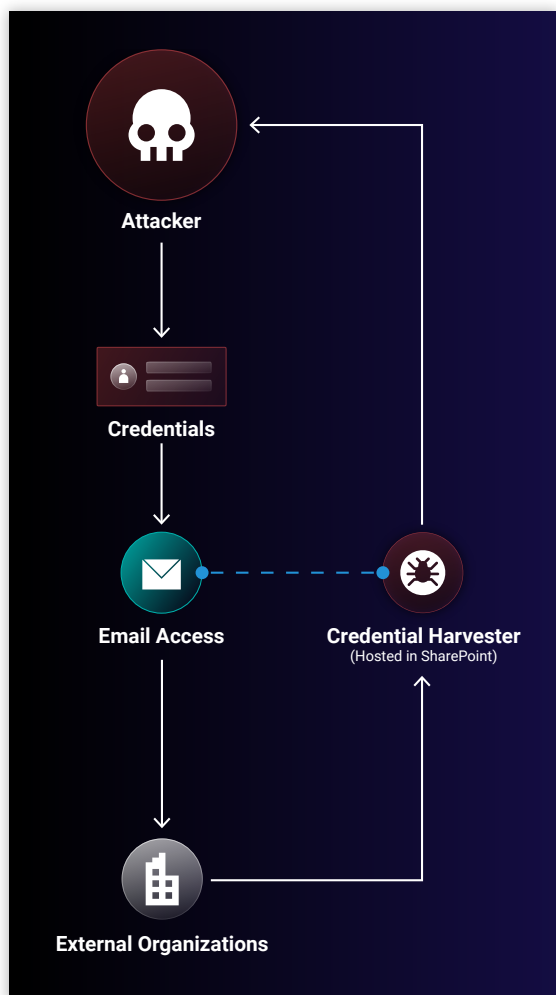
A reliable way to defend against SaaS-based phishing attacks is to detect and block malicious website connections once users click on phishing links within trusted platforms. ReliaQuest provides rules to identify connections to malicious sites, independent of email security tools. If a user clicks a malicious link, alerts like Emergency Domain Threat IOC or POST to Threat Domain will be triggered through GreyMatter, allowing security teams to act immediately.

Case Study

OVERVIEW:

In July 2024, we responded to an alert from a manufacturing sector customer affected by a business email compromise (BEC) attack in which malicious phishing documents were hosted in OneDrive and SharePoint.

BEC is a type of email cybercrime where an adversary compromises an employee's email account to defraud or attack the company.



Due to data retention limits, the exact initial access method could not be determined. However, attackers commonly gain initial access through tactics like spearphishing or social engineering.

In this incident, after compromising the user's account, the attacker created a OneNote document linking to a website hosting a credential harvester.

They then uploaded the OneNote document to the user's SharePoint and used the compromised mailbox to send phishing emails to external organizations, linking the malicious OneNote file saved in the user's SharePoint. By disguising malicious links in this way, the likelihood that email security tools or users will detect the links is significantly reduced.

The attacker also created an email management rule for the account to prevent the user from being alerted to the inbox compromise. This rule filters inbound emails, hiding them in an Outlook folder and marking them as read.

As a result, the end user did not notice the responses to the phishing emails sent from their account and so their security team was not notified. This email rule allowed the attacker to maintain persistence in the compromised inbox for longer, enabling them to extend their phishing campaign to more recipients.

Mitigations and Recommendations

ReliaQuest swiftly detected this activity and deployed Response Playbooks to assist with the customer's response efforts.

These actions included:

Resetting the compromised account's password and terminating its active sessions.

Forcing all devices to log in with the new password.

Deleting the phishing document from SharePoint.

Blocking the domain used by the credential harvester.

These measures helped impede and deter the attacker, allowing the customer to quickly contain the threat and prevent a full-blown attack. The primary function of email security tools is to identify malicious links. However, as the tactic outlined in the case study was developed to directly bypass this function, additional detection and defense measures are essential to avoid compromise. GreyMatter offers an extensive rule library containing detection rules to identify attacks at different stages in the attack lifecycle.

Below are specific detection rules for identifying the indicators of compromise (IoCs) of SaaS-based phishing attacks and the corresponding GreyMatter Containment or Response Playbooks. These Playbooks work independently of email security tools to provide overlapping coverage for more comprehensive security. For the fastest containment, automated incident response should be adopted. Our Automated Response Playbooks can be enabled to automatically contain threats as soon as an alert is generated, improving MTTC and allowing defenders more time to respond.

Detection Rule:

RQ – Emergency Domain Threat IOC

MITRE ATT&CK ID:

- T1566.002 – Spearphishing Link

Summary:

Hidden links in SaaS platforms are designed to circumvent email security tools, increasing the likelihood that a phishing email will reach an end user's inbox. This rule detects web traffic to domains associated with malicious activity, such as phishing credential harvesting sites that users might click on.

Detection Rule:

RQ – Malicious Email Outlook Rule Created via API/Portal

MITRE ATT&CK ID:

- T1564.008 – Email Hiding Rules
- T1070.008 – Clear Mailbox Data

Summary:

When a legitimate email account is compromised and used to send phishing emails, recipients often reply to inform the user that their email has been compromised.

To prevent the user from discovering this and thus causing the attacker to lose access, attackers create email rules to hide inbound emails from the inbox owner. This rule detects when such email rules are created.

Detection Rule:

RQ – Malware Detection in Cloud Storage

MITRE ATT&CK ID:

- T1080 – Taint Shared Content

Summary:

If an attacker hosts a document containing malware within a cloud storage tool, cloud security tools like Microsoft Office 365 Cloud App Security (MCAS) can detect and outline malware signatures. This rule looks for these signatures and alerts on them.

We recommend the following Response Playbooks:



Block Domain: Prevents access to malicious domains by blocking them. When deployed automatically through Automated Response Playbooks, this Playbook immediately blocks malicious traffic, reducing the risk of users entering credentials into credential harvesters or downloading malware.



Reset Password: After a malicious link has been clicked on, this Playbook resets the password of a compromised account. This prevents the attacker from using the account to launch a phishing campaign. This Playbook can be run automatically through Automated Response Playbooks to reset the password as soon as the alert fires, reducing MTTC.



Terminate Session: This closes all active sessions for a compromised account, forcing attackers to re-enter the account's password for access. When run automatically with Reset Password, attackers will be forced out of a compromised account and prevented from accessing it again with the compromised password.



Block Hash: Blocking a malicious file's hash within cloud and endpoint security tools prevents the file from being executed on the network. This prevents further compromise and limits the amount of sensitive data that can be stolen by attackers.

SSRF Threats in PaaS Environments

As organizations expand their cloud environments, they require additional tools to effectively manage them. PaaS solutions like Grafana, Google App Engine and Heroku can help bridge this gap. However, these platforms also introduce risks, as they require extensive environmental access to monitor the functions of other applications. If compromised, this access can be exploited by attackers to increase their attack surface.

SSRF attacks are particularly prevalent against PaaS solutions, as they exploit server code to access internal resources by manipulating URLs. Any application that can import, publish, or read data from a URL could be vulnerable. Attackers can use SSRF to read data from services that are not intentionally exposed to the internet, such as the metadata of cloud servers or database HTTP interfaces. This can potentially expose sensitive information, such as confidential user information or account access information, to attackers. To exploit these vulnerabilities, the attackers must communicate to the service from an external resource and run commands within the cloud environment.

SSRF attacks through PaaS solutions pose significant threats to organizations as they enable attackers to access internal resources and exfiltrate sensitive data. Such data breaches can lead to severe consequences, including:

Service Disruptions

Financial Losses

Reputational Damage

To mitigate these risks and protect critical infrastructure and data, it is essential that organizations establish an effective and resilient security operations strategy to detect and prevent SSRF vulnerabilities. Additionally, PaaS solutions typically include base software that should be included in regular patch management cycles to avoid vulnerabilities that could allow unauthorized access or SSRF attacks.

Case Study

OVERVIEW:

In November 2023, we responded to an alert for a customer in the technology sector regarding suspicious network traffic to the domain `redirect[.]studio` from the PaaS platform Grafana.

The domain, created less than a month before the alert was triggered, was found to have likely conducted SSRF attacks on the Grafana platform.

In addition, open-source intelligence (OSINT) sources, like VirusTotal, have since cited the domain for the same activity on different organizations, which indicates this domain likely conducted a large-scale campaign of these attacks.

In our investigation, we discovered that domain name system (DNS) requests from the AWS instance hosting Grafana were made to the malicious domain, indicating a successful SSRF attempt. We also found that the Grafana instance may have been vulnerable to CVE-2020-13379—an SSRF vulnerability specific to this platform. Although Grafana patched this vulnerability in 2020, its presence in the Grafana instance suggests that it had likely not been updated. This exposes the platform to potential threats and attacks and highlights the critical importance of patch management for PaaS platforms.

Following the attack, the threat actor gained access to additional AWS resources, such as metadata servers and roles. However, the impact of this was limited due to strict scope management of the resources and the timely actions taken by defenders. The consequences of not promptly addressing this activity could have been severe. Had the threat actor remained undetected in the network, they could have escalated their access, leading to unauthorized data manipulation or a data breach.

In response to the alert, we worked with the customer to:

Identify the activity

Provide recommendations for remediation

such as running a Response Playbook to block the malicious domain and updating Grafana to a version that patches the vulnerability.

This case study emphasizes the critical need for regularly updating and patching PaaS platforms to prevent exploitation of known vulnerabilities like CVE-202-13379. Limiting the scope of access for different resources across a network can also significantly reduce the impact of a successful attack. In addition, continuous monitoring and analysis of DNS requests and network traffic can help with detecting and responding to suspicious activity before they escalate.

Mitigations and Recommendations

In addition to strict patch management, we recommend disabling unnecessary metadata services and restricting or disabling insecure versions within cloud environments to prevent adversary access. Attackers often target these services to access additional data and roles within an AWS environment, which they can then use to progress their attack further into the kill chain, as seen in the case study above.

Disabling these services, where possible, can help to limit the exposed attack surface. To enhance management efficiency and visibility in defending against SSRF attacks on PaaS solutions, GreyMatter centralizes logs and alerts from cloud environments. This streamlines operations, improves detection efficiency, and accelerates containment and response times, thereby reducing the impact of a potential attack.

In the event of an SSRF attack attempt on a cloud solution, the following response can be deployed.

Detection Rule: RQ – Cloud Instance Metadata Service – Potential SSRF

MITRE ATT&CK ID:

- T1552.005 – Cloud Instance Metadata API

Summary:

SSRF can be used to query metadata stored within International Material Data Systems (IMDS) to retrieve role credentials. This rule detects indications that an attacker is querying sensitive data. These indications can be identified through cloud security tools like GuardDuty or independently by examining cloud firewall or configuration logs.

We recommend the following Response Playbook:



Block IP: This playbook can be deployed to block malicious IP addresses and prevent attackers from using a malicious IP address to access a compromised account or run additional commands. In an SSRF attack scenario, the source IP address conducting an SSRF attack can be blocked, which will halt the attack until it is reconfigured to launch from another IP address.

Exposing the Risk of Unsecured SSH Keys

SSH is a network protocol crucial for modern network management and cloud services. While SSH keys offer convenience and security, they often lack proper protection, making them easy targets for attackers. **Key management challenges include:**

Key Sprawl:

SSH keys don't expire, leading to unchecked proliferation and unmanaged keys.

Lack of Visibility:

Old keys can provide undetected access to systems, making them prime targets for attackers.

Control Issues:

Anyone can generate SSH keys, often resulting in excessive privileges and security risks.

Administrators often generate and use decentralized SSH keys on an ad-hoc basis to manage firewalls, routers, and other mission-critical systems. Despite their critical role, organizations frequently overlook the security implications of SSH keys. Ineffective management of SSH keys exposes organizational networks to significant security risks. For instance, a single key in the wrong hands can give hackers undetected access to networks, allowing them to create new permanent access keys for continued exploitation. Moreover, compromised SSH keys can give threat actors access to key systems, such as servers with valuable data. This can have a devastating impact on organizations, causing extensive operational, financial, and reputational damage.

Case Study

Overview

OVERVIEW:

In August 2024, an alert fired for an organization in the accommodation and food services sector.

The alert indicated unauthorized modifications were made to SSH keys on an AWS instance, signaling the affected instance faced potential unauthorized access or critical configuration changes.

The alert was linked to the exposure of SSH private keys stored in cleartext, which granted access to a highly privileged virtual machine. This exposure dramatically heightened the risk of unauthorized lateral movement and privilege escalation. It was unclear whether these unauthorized modifications were the direct result of malicious activity or unintentional actions by authorized personnel.

This uncertainty underscores the significant tracking problem associated with SSH keys.

In response to the incident, we recommended the customer review change history and access logs to determine the actor involved in the SSH key modification, assess the necessity of the SSH keys and remove or rotate any not in use, and enable multifactor authentication (MFA) for users with sensitive permissions.

The use of cleartext SSH keys in the cloud, particularly within AWS, amplified the risk of unauthorized access. In cloud environments, SSH keys are essential for remote instance management, making them a cornerstone of security. However, storing these keys in cleartext makes them a glaring vulnerability. This incident underscores the critical need for robust SSH key management practices in cloud environments.

Organizations must understand that using cleartext SSH keys poses severe security risks, including unauthorized access, lateral movement, and privilege escalation. Therefore, they should implement enhanced security measures to alleviate these risks and ensure critical data remains protected.

Mitigations and Recommendations

To mitigate the risks associated with unsecured SSH keys, the first step is to discover and map all existing keys within your network. Analyze these keys for potential vulnerabilities, such as unnecessary root-level access and weak key lengths. Remediate identified risks by rotating or replacing outdated keys and removing unused or orphaned keys. Establish a process for regularly generating and rotating fresh key pairs.

GreyMatter addresses the challenge of unsecured SSH key exploitation by providing a centralized view of SSH key activities. It tracks in real-time how keys are being used and detects unauthorized modifications by integrating seamlessly with multiple cloud security tools, including CSP logs, which capture API calls made to cloud services. This comprehensive visibility allows security teams to quickly identify and respond to potential threats, reducing alert fatigue and streamlining investigations. By centralizing these capabilities within a single platform, GreyMatter ensures advanced SSH key management and enhances your organization's overall security posture.

To complement these proactive measures, the implementation of robust detection rules is vital. Below, we outline a key GreyMatter detection rule, its MITRE ATT&CK ID, and containment actions to help safeguard your infrastructure.

Detection Rule: RQ – Cloud Instance SSH Keys Modified

MITRE ATT&CK ID:

- T1098.004 – SSH Authorized Keys

Summary:

This alert detects when the SSH keys for an instance are modified. This could indicate that a new account has been created or a new key has been added to access an existing account on a compute instance.

We recommend the following action:



Manual Action Required: As modification of an SSH key alone is not a strong indicator of malicious activity, a manual response is required. We recommend resetting the SSH keys for the affected instance, and investigating logs to identify the source of the changes and monitoring for any further anomalies.

Protecting Against Cloud Environment Hijacking

Compromised API keys can give attackers initial access to cloud environments across various CSPs, such as AWS, Azure, and Google Cloud. Once inside, attackers can hijack services for expensive cryptocurrency mining operations, steal sensitive data, or host phishing campaigns.

Attackers might target virtual machines (instances) to deploy new machines for cryptocurrency mining, resulting in large, unexpected bills for organizations if the new machines are allowed to run. Buckets storing sensitive data can be exploited to compromise accounts, steal user information, or extort organizations by threatening to release the sensitive data. Attackers take advantage of the significant brand and operational damage to persuade companies to pay a ransom. Compromised accounts can also provide attackers with access to additional cloud resources and higher privileges, allowing them to progress their attack further in the kill chain.

Email services, like Simple Email Service (SES), can also be hijacked for phishing campaigns. By hijacking the company's legitimate email resources within SES, attackers can disguise their phishing emails as emails sent from within the organization. Attackers may even send phishing emails to third-party companies that work closely with the organization. These emails can cause damage to the organization's brand image and hurt relationships with third parties and customers, which could have a significant and lasting impact on the organization's business operations.

Case Study

Overview

OVERVIEW:

In July 2024, we investigated malicious activity in an AWS environment for a customer in the professional, scientific, and technical services (PSTS) sector.

Initial access was likely gained through exposed API keys to an AWS account used by the organization for AWS resource deployment.

This access allowed the attacker to run discovery commands, such as `DescribeInstances` and `ListBuckets`, to map different resources. In this incident, the attacker specifically targeted SES to deploy an outbound phishing campaign.

The attacker ran the `GetSendQuota`, `ListVerifiedEmailAddresses`, and `GetSendStatistics` commands to understand the email sending limits and metrics of the compromised account. These metrics allowed the attacker to plan their phishing campaign by understanding the account's permissions and typical behavior, enabling the attacker's activities to blend in with the account's normal actions.

A few weeks later, the threat actor logged into the deployment account again and checked if they could create other accounts with the command `SimulatePrincipalPolicy`. Once these permissions were confirmed, to avoid suspicion, an account was created with the command `iam:CreateUser` to disguise the account as an SES service account.

Defenders are less likely to be suspicious of an email service account sending high volumes of emails compared to a resource deployment account sending the same volume of emails.

The SES service account was used to create AWS instances, buckets, roles, users, and email identification—all the elements needed for a phishing campaign. In an effort to make the phishing emails appear legitimate, requests were made to increase the email sending limit for the compromised accounts and assign DomainKeys Identified Mail (DKIM) attributes to them. With all these steps completed, the attacker then launched their phishing campaign.

To remediate this incident, ReliaQuest recommended that the customer:

Rotate compromised
API keys

Terminate any active live sessions
for the compromised accounts

Revert the unauthorized changes
made by the threat actor

This case study highlights the need for organizations to closely monitor their cloud environments and API key usage to ensure attackers cannot access and manipulate critical cloud resources.

Mitigations and Recommendations

To enhance security and prevent similar incidents, we recommended the customer disable or rotate compromised access keys to prevent further unauthorized access, isolate affected resources, revoke active sessions for compromised accounts, and revert any changes made by the threat actor, including the removal of unauthorized accounts and storage buckets.

Exposed API keys pose a significant risk as they grant attackers damaging access to a cloud environment. Within AWS, organizations can use the API Gateway to generate an SSL certificate and then use its public key in the backend to verify that HTTP requests are from the API Gateway. This enables the HTTP backend to control and accept only requests originating from the API Gateway, even if the backend is publicly accessible. This solution acts as a second identity verification method and ensures only authorized users can use API keys.

A proactive approach to defense is also highly beneficial. ReliaQuest's GreyMatter Digital Risk Protection (DRP) identifies exposed API keys across the open, deep, and dark web and alerts customers when these keys are detected, such as those found in GitHub repositories or publicly available technical documents. This allows customers to take swift action to secure their cloud environments. In addition to API key exposure, GreyMatter DRP monitors for data leaks, brand impersonation, and threat actor activities, providing comprehensive insights to mitigate a wide range of digital threats.

Detection Rule:

RQ – Exposed Access Key

MITRE ATT&CK ID:

- T1190 – Exploit Public-Facing Application

Summary:

Attackers are known to search through public code repositories and online documents for API keys. This alert looks for API keys online that should not be publicly available.

Detection Rule:

RQ – Cloud API Enumeration

MITRE ATT&CK ID:

- T1087.004 – Cloud Account
- T1069.003 – Cloud Groups

Summary:

If attackers gain access to an API, they will likely begin by mapping the cloud environment using commands like those in the case study above. This rule detects multiple API commands that can be used for reconnaissance.

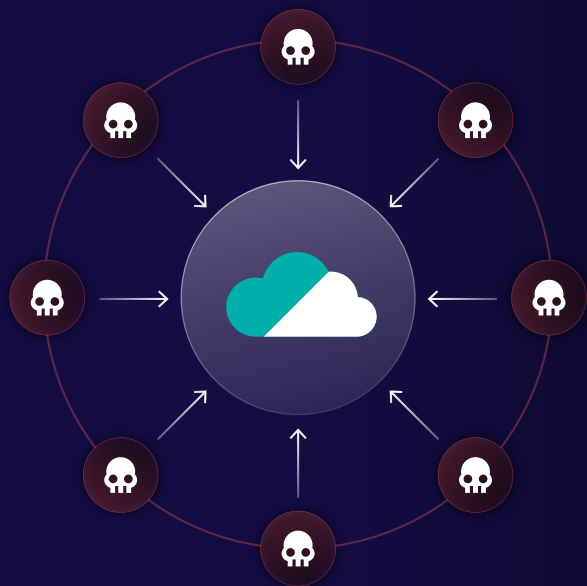
We recommend the following Response Playbook:



Block IP: If attackers have begun to probe the cloud environment after gaining access to an API, blocking malicious IPs prevents attackers from using the IP address to access compromised accounts or run additional commands. This limits their ability to carry out further malicious activities within the environment.

Cyber Threat Projections

As cloud adoption accelerates, enterprises are encountering new and complex cybersecurity challenges. Key trends and risks are emerging that will demand heightened vigilance and proactive defensive strategies.



Cloud Exploit Development on the Rise

According to Forrester's Infrastructure Cloud Survey, cloud decision-makers have already moved an average of 39% of their application portfolios to the cloud and plan to migrate an additional 53% within the next two years.²

As enterprises continue to adopt cloud technologies, threat actors are expected to focus more on developing specific exploits targeting these environments. This trend is exacerbated by the still high percentage of unencrypted data in cloud environments, making them attractive targets for attackers.

For enterprises, this means a higher risk of data breaches and cyberattacks, emphasizing the need for robust encryption practices and advanced threat detection measures.

Surge in APTs Employing Cloud Services for C2 Operations

August 2024 saw a marked increase in advanced persistent threat (APT) espionage operations leveraging cloud services for command-and-control (C2).³ Abusing free cloud services offers several advantages for attackers:

They are quick, cost-effective solutions that enable stealthier communication within networks. Security products and firewalls are less likely to flag connections to widely used services like Microsoft OneDrive or Google Drive as suspicious compared to connections to less recognized IP addresses. Due to the improved anonymity the technique offers and the increasing adoption of cloud services among organizations targeted by APTs, this technique is expected to become even more prevalent over the next year as attackers aim to blend seamlessly with legitimate network traffic.

For enterprises, this means that traditional security measures may not be sufficient to detect these threats. Organizations should implement more sophisticated monitoring and anomaly detection systems to identify and mitigate these stealthy attacks.

The ReliaQuest GreyMatter platform provides comprehensive visibility and advanced threat detection capabilities, ensuring that enterprises can stay ahead of evolving threats.

Hybrid Cloud Misconfigurations

The hybrid cloud—a computing environment that combines an on-premises data center with a public cloud—is expected to become increasingly prominent. The hybrid cloud market size was valued at \$125.1 billion in 2023 and is projected to reach \$558.6 billion by 2032.⁴ With its rising prominence, specific misconfiguration issues within this environment are likely to emerge. IT staff unfamiliar with hybrid setups may improperly configure security settings, creating an attack surface for threat actors. This risk is compounded by the unique configurations of hybrid environments; for instance, traditional network defenses may not seamlessly adapt to cloud aspects, resulting in security blind spots that can be exploited.

As a result, enterprises must implement proper configurations and robust security settings to mitigate these risks and protect organizational assets. They should also invest in IT staff training and adopt comprehensive security solutions that operate effectively across hybrid environments.

Conclusion

In today's landscape of sophisticated and evolving cyber threats, a comprehensive, multi-layered security approach is essential to protect cloud environments. This involves deploying flexible and modular options that seamlessly integrate across various cloud service providers and security tools to effectively manage data, costs, and risks.

By unifying the **three primary pillars of cloud security**, organizations can achieve a holistic view of their security landscape:

This integration simplifies the investigation process, making it accessible to teams with varying levels of expertise. Traditionally, security information and event management (SIEM) solutions handle this task by centrally collecting and analyzing data. However, SIEM solutions can be costly and may lack the integration capabilities needed across diverse tools.



The ReliaQuest GreyMatter Platform Offers a Superior Solution.

Our security operations platform integrates with your existing and future security tools and extracts data in a scalable manner. This provides organizations with comprehensive visibility and operational efficiency through bi-directional APIs.



GreyMatter's seamless integration across multiple cloud security layers helps reduce alert fatigue and streamline investigations by centralizing tools through a single platform, eliminating the need to move data or add additional tools.

This ensures robust cloud security and effectively addresses cloud-specific attack vectors such as unsecured SSH keys, phishing links hosted through cloud storage, SSRF vulnerabilities, and API compromises.

Through GreyMatter, enterprises are empowered to proactively defend against increasingly complex cyber threats, ensuring the security and integrity of their cloud assets.

Appendix: Endnotes

1. <https://www.idc.com/getdoc.jsp?containerId=prUS52460024>
2. <https://www.forrester.com/surveys/forresters-infrastructure-cloud-survey-2023/SUS20178>
3. <https://www.csoonline.com/article/3483919/apt-groups-increasingly-attacking-cloud-services-to-gain-command-and-control.html>
4. <https://www.imarigroup.com/hybrid-cloud-market>